

自动代码审计的天花板

项目计划书

Zhaohe Dong

2026 年 9 月 17 日

本文件是内部工作计划，不是对外材料。其中对现状的描述包含全部已知的负面结果与已撤回的主张；凡未通过独立跨厂商评审的数字，均标注其状态，不作为论据使用。

1 核心问题与定位

一个自动审计者读一段不是它写的代码，决定要不要拦下来。它能拦住多少，天花板由什么决定？

这个问题的难点不在提问，在测量。通行做法是让模型评价模型，于是“审计者没看见”与“对错本身没有定义”混在一起。本项目的全部设计都服务于把这两者分开：让解释器执行的隐藏测试充当唯一判准，然后一次只操纵一个变量——谁在读、规则手册怎么写、读几次、题目有没有把话说清楚。

定位需要收窄。项目早期的叙事是“AI 审计存在一个天花板”。两轮外部评审都指出这个叙事撑不住，本计划采纳该判断。可辩护的定位是：

在给定任务、证据、审计协议与预算下，重复的 LLM 审查能增加多少有效诊断？这些收益付出了多少误报代价，又在多大程度上受任务规格完整性的限制？

2 已建成的装置

2.1 判准与分层

基底为 EvalPlus (HumanEval+/MBPP+)，中位题目 41 词规格、6 行参考代码。生成器 claude-haiku-4-5 看规格与可见测试写代码；隐藏测试只喂给解释器，审计者永远看不到。分层完全由执行结果决定：

层	条件	规模
P (有缺陷)	过可见测试、挂隐藏测试	110 个实例 / 56 个题目
C (“正确”)	两套测试均通过	150 个抽样实例
F (丢弃)	未过可见测试	不进入分析

“正确”打引号是认真的：它仅表示“通过隐藏测试”，是解释器给的标签，不是符合规格的保证。相应地，“误报”指对通过测试的代码提出标记，而非已证明的审计者错误。

2.2 测量量

union recall at K : K 次独立阅读中至少一次拦下的缺陷实例比例，对全部 $\binom{8}{K}$ 个子集精确平均而非抽样。配套量为并集误报率。方法章立有硬规矩：报召回必须同时报它花掉的误报率——因为全部拦下可得 100% 召回。

观测单位是实例，重抽单位是题目（同题目的实例不独立）；区间为 10,000 次题目级聚类自助法，Wilson 区间并列打印并标注“过窄”。 K 次阅读是重复测量，不是 K 个独立观测。

2.3 证据闸门

1. 预注册：总体、假设、主要结局、区间、kill 条件、预算、停止规则，全部在第一次模型调用之前写死。
2. 编号修正案：任何偏离记为修正案，在其生效的那一步之前提交，并记录当时已知什么。
3. 跨厂商评审：报告交由另一厂商的模型审查，其可读原始记录、重跑分析、逐句核对，结论须为“quotable”方可放行。
4. 主张清单 (CLAIMS.md)：列出论文被允许陈述的每一句话及其必须携带的标签，同时列出证据不支持、禁止出现的说法。

3 当前证据状态

3.1 已通过评审的发现

- **C1** 重复阅读收益递减但未饱和。 $K=1$ 的 10.7% 升至 $K=8$ 的 30.0% [20.0, 40.7]，误报 16.0% [10.1, 22.3]。第八次仍增益 1.93 点 [1.14, 2.78]，高于预注册的 1.0 点平坦化门槛，故“饱和”一词已撤下。三族二十次阅读合计 48.2% [36.7, 60.0]。
- **C2** 换模型的影响大于换次数，但该对比过不了自身的关：更强的同厂商模型召回 -26.4 点 [-37.3, -15.6]，然而它误报仅 3.3% (对 16.0%)；换宽松严重度规则符号反转；两条路由采样方式不同（一条发 temperature 0，一条不发）， $K=1$ 时差距仅 -10.1。且存在反例：另一跨厂商模型在一半阅读次数下两轴皆优。
- **C3** 规则手册加一句话使标记从 10/56 增至 25/56 (+26.8 点 [13.6, 40.4])，代价为正确代码上 +12.50 点；但在隔离该规则的对比上，隐藏测试通过率仅动 +5.36 点 [-0.89, 12.07]， $p = 0.146$ ，区间跨零。
- **C4** 110 个缺陷中 57 个被所有阅读漏过；重新分类后两位评分者一致认为 **44/57 (77.2% [62.1, 91.1])** 是规格未确定隐藏测试所问之事。外部佐证：他人独立点名的 11 道题目中，我方冻结标签吻合 9 道。

3.2 2026 年 9 月 15 日：五项评审，五项全拒

研究	状态	缘由
study 17	已修	第 8 轮的修复立了新过强主张：声称测试证明了一条从未执行的重建链
study 19	已修	改名只做一半；且把工具准入说成“更窄”，实际更宽
study 20	已修	把八读标记覆盖写成已确立的更高天花板
study 22	已撤回	注册要复原失败输入的过滤器，实现只查字符串非空
study 23	作废·重跑中	给模型看的可见测试缺 class 头，300 道题全部语法损坏

两项是被上一轮修复本身拒掉的，且偏差均指向“让工作显得更好”的方向。这不是严谨的证据，是尚未收敛的证据。所幸“未过评审的数字不进正文”这条规矩，使五连拒未逼出任何已认定主张的撤回——论文四个结果小节依赖的三项研究都是先过评审才进来的。

4 已识别的最大弱点

按严重程度排列，本计划的下一阶段直接针对前三条。

- W1. C4 的评分者不独立。**这是最有意思的发现，也是防护最薄的一条。两位评分者是一个模型与作者本人——后者写了评分标准、知道先前标签、知道该主张的分量。且“规格是否确定”本质上是判断，解释器管不了。为其设计的前瞻性检验（study 22）已整个撤回，因此 C4 目前只有事后证据。
- W2. 对照组已做，但从未进入论文。**残差重分类之外，两位评分者也标注了 53 个已抓到的缺陷（L1-flagged.csv / L2-flagged.csv，经核查为独立评分而非复制）。共识标签下：漏检组 $46/68 = 67.6\%$ 规格未确定，已抓到组 $24/53 = 45.3\%$ ，差 +22.4 点；两组评分者一致率分别为 88.2% 与 96.2%。这是 C4 现在缺的那个对照，它支持 C4——漏检确实更集中在规格未确定的实例上，但并非全部。该对比至今未写进任何报告，也未过评审，须补上区间与标签后送审。
- W3. 关键实验未做。**严重度阈值扫描——把不同审计者拉到同一误报率再比——决定 C2 与 C5 能否成立，而所需 findings 均已归档，只改评分规则、几乎不花钱。
- W4. 单基底单生成器。**第二基底作废、注入研究撤回后，论文只剩一个基底、一个生成器支撑，且该基准记忆污染问题被广泛批评。
- W5. 区间覆盖未验证。**主区间为 56 个题目簇上的自助法，其在本聚类设计下的覆盖率未经模拟验证；本项目此前已有两个区间构造被评审测出覆盖率为 0.416 与 0.075。

5 下一阶段工作

5.1 P1 ——人类评分者与对照组（针对 W1、W2）

这是性价比最高的一项，且不需要任何模型调用。

设计：把 110 个缺陷实例全部交给评分者，对审计结果盲化并打乱顺序，只问一个问题——“规格的散文是否确定了隐藏测试所期望的值？”

- 主要对照已有初值，需独立复核：已抓到与漏检两组“规格未确定”的比例差为 +22.4 点 (45.3% 对 67.6%)。但该数字的两位评分者仍是一个模型与作者本人，因此它证实的是 C4 的方向，不是 C4 的独立性。P1 的任务是让一位项目外的人类在盲化条件下重做这个对比。
- 附带产出：作者对同 57 个实例的重测信度。该评分标准已经因提问顺序改变而翻转过一次，其稳定性本身是值得记录的量。

独立性限制必须写明：作者曾作为 L1 评过那 57 个漏检实例，故该部分是重测而非独立评审；53 个已抓到实例是新的。真正的独立评审仍需一位项目外的人类，哪怕只标 30 项。

5.2 P2 ——严重度阈值扫描（针对 W3）

在单一基底上对每个审计者族生成召回-误报曲线，所有跨族比较在匹配的误报率上进行。现有两个阈值点（BLOCKER、任意 finding）已在手，补第三、第四个阈值只需对已缓存的 findings 重新评分。这是决定 C2/C5 生死的实验，却几乎免费。

5.3 P3 ——规格澄清实验（针对 W1 的因果性）

保持代码与可见测试完全不变，只补上规格中从未交代的行为规则（同分如何处理、空输入返回什么），并配一个长度相当、但不解决任何歧义的安慰剂改写作为对照。

条件	代码	可见测试	规格
原始	不变	不变	原始描述
澄清	不变	不变	补足缺失的行为规则
安慰剂	不变	不变	增加等长但不解决歧义的文字

若正确诊断率在澄清条件下上升而在安慰剂下不升，规格的不完整就在起因果作用；若不升，则 C4 只是“难实例的两个属性相关”。该设计操纵规格，而重分类与注入总体都只是在规格上做条件——这是它们做不到的。

5.4 P4 ——收尾 study 23

重跑正在进行中。self 族 8 臂已全部完成；cross 族因供应商限流中断约 23 小时后已恢复，正在补齐。预算封顶 \$45（预注册 Amendment 2），当前约 \$30。

6 第二阶段：审计形态与 AI4S

第一阶段（P1-P4）是把现有主张钉牢。第二阶段是往外走，分两步：先广泛调研当前已有的审计架构与方法，再结合 AI4S 数据集做能落地的分析。这个顺序有两个理由：外部评审明确指出本项目文献 engagement 不足（现有引用仅 11 条），调研能直接补上；而先看清别人做过什么，才能避免把预算花在已被回答的问题上——本项目自己的 study 7 就是例子。

6.1 P0’ ——先做调研，再做实验

已知的自身空白：study 7 已经用十五种架构（holistic/decomposed × cross/self/cheap-cross × union/majority/多 draw）在 ≤ 6.7% 误报约束下做过网格搜索，结论是没有一种胜过在产的 holistic-cross，它就在 Pareto 前沿上（tri_union 召回 41.8% 但误报 33.8%，换不回来）。因此不应再做架构排列组合，边际收益已被自己证明很低。

调研应集中在那十五种没有覆盖的轴上，并在每条上确认是否已有他人工作：

未覆盖的轴	为什么值得
工具使用（可执行代码）	十五种全是只读式。我们测到的可能是“阅读”的天花板，不是“审计”的天花板
顺序 / 自适应	十五种全是并行合成，没有接力：审计者 2 看得到审计者 1 的 findings
性质导向（写不变量而非 findings）	输出可执行 ⇒ 判准不再是判断
辩论 / 对抗	有文献基础，但成本高，需先看已有结论
检索增强	给审计者看相似的已知缺陷

交付物是一份带引用的对照表：每条轴上别人做到哪、用什么判准、我们能加什么。这份表同时是论文相关工作章的材料。

6.2 P5 ——只读式 vs 工具辅助审计

架构侧唯一的大空白，也是二选一的干净对照。给审计者一个解释器：它可以自己写测试、自己跑、自己看崩在哪；但不给隐藏测试、不给标准答案。其余一切（基底、实例、规格、可见测试、K、严重度规则）与 ceiling 1 冻结的配置相同。

回答的问题是：天花板是模型的性质，还是形态的性质？若工具辅助显著突破 30.0%，则本项目全部已认定主张的适用范围都必须收窄到只读式代码审查——这正是论文当前声明的范围，届时该声明将从“保守的自我设限”变成“已被测量的边界”。

预注册须事先写死：工具预算（调用次数、墙钟）、可执行环境、以及“审计者自己写的测试通过与否”不得进入判准——判准仍然只有隐藏测试。

6.3 P6 ——科学代码中“规格未确定”的比例

不在 AI4S 基底上重做天花板研究，只搬那个诊断动作。假设是：

科学代码的规格天然更不完整——容差取多少算收敛、单位、随机种子、数值稳定性极少写进题面——因此“规格未确定”的比例应显著高于玩具 Python 的 67.6%。

若成立，这是一条直接给 AI4S 领域的结论：继续堆模型的边际收益有上限，而上限由任务定义的质量决定。它不依赖本项目的模型、工具链或基准。

候选基底与两个已知障碍。SciCode (NeurIPS 2024 D&B) 覆盖物理、数学、材料、生物、化学五个领域，80 个主问题拆为 338 个子问题，带科学家标注的金标准解与测试用例。但直接套用本项目的装置有两个硬问题，必须在预注册里先解决：

障碍 1： 它没有“可见/隐藏”测试划分。substrate 2 正是因为自己发明这个划分而整轮作废——一切出来的可见测试 300 道题全部无法解析。同一个坑不得再踩。

障碍 2： 求解率过低。最好的模型在最真实设定下仅解出 7.7%，绝大多数候选会落进丢弃层，P/C 两层都凑不出样本。

因此 P6 的设计绕开生成与审计：不生成候选、不跑审计，只取现成的失败案例与题面，交由评分者判断“规格是否确定了失败处应返回什么”。成本接近零，且不触碰上述两个障碍。

6.4 P7 ——不变量审计（科学代码独有的机会）

科学计算有一样玩具 Python 没有的东西：物理不变量——能量守恒、动量守恒、对称性、极限情形、量纲一致性。它们是判准，且不依赖任何测试套件。

设计：不问审计者“这段代码有缺陷吗”，而问“它违反了哪条不变量”，并要求它给出可执行的检查。该检查随后由解释器运行。

这等于绕开了规格确定性问题——不再需要题面把话说死，因为物理定律替它说了。同时它也是 P0’ 表中“性质导向”那一行的具体实现：审计者的输出从判断变成可执行断言。

风险：不变量可能过于宽松（守恒成立但结果仍错），也可能过于严格（数值误差触发假阳）。因此 P7 须先做小规模可行性验证——在 20-30 个已知缺陷上确认不变量检查的区分度，再决定是否扩大。不通过则记录并停止，不追加预算。

7 预算与时间

项	模型开销	人力	说明
P1 人类评分与对照	\$0	约 4-6 小时	无模型调用；盲化数据集由脚本生成
P2 阈值扫描	约 \$0	约 1 天	仅对已归档 findings 重新评分
P3 规格澄清实验	约 \$40-60	约 3-5 天	需新生成与新审计；应单独预注册
P4 study 23 收尾	余 \$15 以内	已自动化	守护进程运行中
第二阶段			
P0’ 调研	\$0	约 3-5 天	五条未覆盖轴的带引用对照表；同时是相关工作章的材料
P5 只读 vs 工具辅助	约 \$60-100	约 1 周	工具调用使单次审计成本上升，需单独预注册预算上限
P6 科学代码规格比例	\$0	约 1 周	不生成、不审计，只评分；绕开 SciCode 的两个障碍
P7 不变量审计	约 \$15（可行性）	约 1 周	先在 20-30 例上验区分度，不通过即停

排序理由。P1 与 P2 几乎不花钱却直接打在最弱的两环上，应先做；P3 是唯一能把相关性变成因果主张的实验，但需要预算与新的预注册，应在 P1 结果出来之后再启动——若 P1 的对照显示漏检组与已抓到组比例相近，P3 的前提就不成立，应当改题而非照做。

第二阶段的顺序是先调研、再落地：P0' 不花钱，却能防止把预算花在已被回答的问题上——本项目自己的 study 7 就是这样一个例子，十五种架构的网格搜索得到的是一个空结果。P6 同样零成本且不依赖第一阶段的任何结论，可与 P0' 并行。P5 与 P7 都要花钱，都应等 P0' 的对照表出来之后再启动：若调研显示某条轴已被他人用更强的判准回答过，该项应改为复现或引用，而不是重做。

一条跨阶段的硬规矩：任何新基底在第一次模型调用之前，必须先跑一次“模型将看到的文本能否解析”的闸门。这是 substrate 2 用一整轮作废换来的教训——当时可见测试文件 300 道题全部无法解析，而审计者与生成器都读了它。

8 论文叙事

拟采用三幕结构，与项目的真实发生顺序一致：

- 第 1 幕 从产品出发。我们造了一个跨厂商代码审计器并把它发出去了。认真测量之后，它在缺陷上的八读并集召回是 30.0%，代价是正确代码上 16.0% 的误报；而且标记不等于抓到——一次阅读里它对 110 个缺陷提出 9 条 finding，真正说对失败行为的只有 5 到 7 条。
- 第 2 幕 追问天花板。于是把“审计者能抓到多少”拆开：谁在读、规则手册怎么写、读几次、题目有没有把话说清楚。四条发现在此，包括最反直觉的那条——漏掉的东西里 67.6% 是规格根本没规定隐藏测试在问什么。
- 第 3 幕 到 AI4S 去检验。把这套诊断搬到科学代码上：那里的规格更不完整（容差、单位、收敛判据、数值稳定性极少写进题面），因此“规格未确定”的比例应当更高。若成立，这是一条对 AI4S 方向直接有用的结论。

8.1 为什么这个叙事比原来的好

原叙事是“AI 审计存在一个天花板”。两轮外部评审都指出它撑不住：三项发现在文献里已有先例，而“天花板”一词被自己的预注册门槛否掉。三幕结构解决了三个问题——它给测量提供了真实的动机（产品没达到预期，所以去查为什么），它让负面结果成为论据而非尴尬（一篇讲“我们试过、这是学到的”的论文可以自然吸收撤回的研究），它把射程从玩具 Python 延伸到一个有人关心的领域。

8.2 三条必须先钉死的约束

一、不要说“失败的 CrossAudit”。记录不支持这个词。study 7 用十五种架构做过网格搜索，在产架构就在 Pareto 前沿上，没有一种在误报约束下胜过它。所以它不是做砸了的产品，而是一个按设计工作、但天花板比预期低的产品，并且低的原因有一大半不在它身上。“失败”是一个比“已测量的天花板”更弱也更不准确的说法。诚实的措辞是：我们发出了一个审计器，认真测了它，发现天花板不在我们以为的地方。

二、叙事不得重排证据。这是本项目最大的特有风险。整套纪律建立在“假设先于数据”之上，而一个“从失败出发、发现了 X”的故事，天然诱使人把一个更混乱的真实过程整理成一条干净的因果链。论文必须继续逐条标注哪些是预注册主分析、哪些是探索性、哪些是看过结果之后的修订。CLAIMS.md 的存在正是为了防止这件事，叙事不能凌驾于它。

三、第三幕目前还不存在。P6 与 P7 尚未运行。因此当下有两个选择：先跑 P6 再写第三幕，或者把第三幕写成计划而非结果并明确标注。不可以把尚未做的实验写成已有的发现，哪怕只是叙事上的暗示。建议取前者——P6 零成本，是三项里最便宜的一项。

9 交付物

- 近期：P1 的盲化评分数据集与结果表；P2 的召回-误报曲线；study 23 的重跑报告（按 Amendment 2 与作废轮并列，不附 p 值或区间）。
- 论文：当前 7 页，ICML 风格预印本。硬性阻断——四项在评审中的研究全部通过、或其数字全部移除之前，不上 arXiv、不投任何会议。
- 第二阶段：P0' 的带引用对照表（五条未覆盖轴）；P5 的只读 vs 工具辅助对照，它决定现有主张的适用范围是否必须收窄到只读式审查；P6 的科学代码规格未确定比例，这是一条可直接交付给 AI4S 方向的结论。
- 可复用产出：本项目认为价值高于论文本身的，是那个诊断动作——把失败案例重新分类，区分“模型的局限”与“需求的沉默”，并报出比例。该动作不依赖本项目的模型、基准或工具链。

10 风险

- P1 的对照可能证伪 C4。这是设计它的理由，不是它的风险。若发生，应如实报告并改写论文主张，而非换一种切法直到结果顺眼。
- 评分标准不稳定。已知它会随提问顺序翻转。P1 的重测信度正是为量化这一点。
- 供应商可用性。study 23 已因限流停摆约 23 小时。所有长跑须在耐久目录下由守护进程承载，并设中途停机线。
- 循环论证。研究对象是 LLM，评审者、评分者之一亦是 LLM。缓解手段是：判准为解释器而非模型；预注册；跨厂商评审。但在判准为“判断”的地方——恰是 C4——该缓解不成立，这正是 P1 与 P3 存在的理由。